



DCC Level 0 Assessor Guide

Version 1.0

INTRODUCTION	3
DEFENCE CYBER CERTIFICATION/CYBER RISK PROFILE LEVELS	4
LEVEL 0 DEFENCE CYBER CERTIFICATION PROCESS	6
IASME Platform	7
LEVEL 1-3 DEFENCE CYBER CERTIFICATION PROCESS	7
THIRD-PARTY ASSISTANCE	8
DETERMINING SCOPE	10
ANSWERING THE QUESTIONS	11
APPLICANT'S EVIDENCE	12
Documentation and Evidence Collection	12
Adequacy of evidence	13
Document retention	13
Scoring Process	14
DCC Applicant Data (IASME Portal)	14
DCC Core Questions/Controls Labelling	15
CONTROL GUIDANCE	16
Control ID: 0001	16
Control ID: 2314	18
Control ID: 2500	20



Introduction

The Defence Standard (Def Stan) 05-138 was introduced in 2015 as part of the UK Government's national cyber security programme, responding to escalating cyber threats. Over the past decade, the defence standard has evolved, and its latest iteration, issue 4, marks a pivotal shift. This version expands the Defence Standard's scope to enhance the overall resilience of an organisation against threats.

The Ministry of Defence (MOD) recognises the importance of ensuring suppliers adhere to the Defence Standard. This document serves as a guide to help applicants prepare for an assessment against the Def Stan 05-138 i4.

By providing a structured and consistent approach to these assessments, MOD seeks to uphold the highest level of cyber security across its supply chain. The Defence Standard sets out the criteria for suppliers in its 148 controls, which are applied into four progressively stringent levels. MOD suppliers are expected to attain a level of security specified in their contracts with the MOD, which is referred to as the Cyber Risk Profile.

The overall aim of this certification scheme is to enhance the cyber resilience of the organisations applying for certification. Whilst some organisations may already meet the controls, others may be deficient in some areas. As part of the application, these areas will become apparent and remediated prior to assessment.



Defence Cyber Certification/Cyber Risk Profile Levels

A Cyber Risk Profile level will be assigned to any new procurement/contract or requirement by the MOD awarding body. This level then defines which controls the supply chain is required to adhere to.

The Defence Cyber Certification scheme is used to provide assurance that controls have been met. It is important to note that the Cyber Risk Profile and Defence Cyber Certification levels are the same.

Applicant organisations may, under this new Defence Cyber Certification scheme, apply for assessment and then certification at any level. This allows them to demonstrate compliance with the chosen level by means of a certificate and will remove the need for future assessments on a contract-by-contract basis for levels less than or equal to their certification.

There are 148 controls in total, but no single level contains all the controls. This is due to some controls overlapping or being replaced by more comprehensive controls at a higher level.

The Defence Cyber Certification levels are:

Level 0 (3 controls)

Level 0 is normally assigned where there is a very low level of assessed cyber risk to a supplier delivering an output. It requires supplier organisations to demonstrate basic cyber security practices and forms the foundation level for all future assessments higher than Level 0.

Level 1 (101 controls)

Level 1 is normally assigned where there is a low to moderate level of assessed cyber risk to a supplier delivering an output. It requires supplier organisations to demonstrate a comprehensive cyber security programme with good practices.

Level 2 (139 controls)

Level 2 is normally assigned where there is a high level of assessed cyber risk to a supplier delivering a contracted output. It requires supplier organisations to demonstrate advanced cyber security oversight and planning which drives robust organisational and cyber practices.



Level 3 (144 controls)

Level 3 is normally assigned where there is a substantial level of assessed cyber risk from a supplier delivering a contracted output. It requires supplier organisations to demonstrate expert cyber security capabilities that fully take advantage of the 'defence in depth' methodology to appropriately protect the organisation against new and evolving threats.

The Level 3 assessment will be conducted as part of a pilot scheme, incorporating a hybrid approach that combines both Level 2 and Level 3 controls. Applicants will be required to provide responses and evidence for all Level 2 controls as well as all Level 3 controls, totalling 145 controls.

- This pilot scheme is currently the only pathway to achieve Level 3 certification. It offers flexibility for organisations pursuing Level 3 by allowing them to:
 - Achieve Level 3 certification if the Level 3 pass mark is met.
 - Achieve Level 2 certification if the Level 2 pass mark is met but Level 3 pass mark is not achieved.



Level 0 Defence Cyber Certification Process

The certification process is:

1. During this early phase, the Applicant contacts IASME regarding their Level 0 Assessment and certification. In the future, the Applicant will be able to visit the IASME website for a list of Certification Bodies.
2. IASME sends the Applicant a list of authorised Certification Bodies.
3. The Applicant contacts one of the Certification Bodies.
4. The Certification Body sends the Applicant log-in details for the assessment platform. (See IASME Platform details below)
5. The Applicant completes the answers with 'limited' support from the Certification Body. This is detailed in the section "Third-Party Assistance".
6. The Applicant 'submits' their assessment on the platform.
7. The Certification Body assesses the submission and marks evidence with the Applicant on a video conferencing call.
8. The Certification Body completes the marking on the platform. This automatically creates a report and sends a pass / fail email. A certificate / badge will also be sent if the assessment has been passed.

IASME will select a random number of assessments to moderate at a later time.

Applying for a Level 0 Defence Cyber Certification should not require significant changes for organisations with a base level security posture. They should be able to use existing policies and processes to meet the majority (if not all) of the controls.

They will, however, need to take a phased approach to prepare their submission starting with determining the scope.



IASME Platform

Level 0 assessments will use the IASME platform whereas Levels 1–3 will record results, evidence and scoring (theoretical) on the Applicant's own systems or an MOD platform – (details to be confirmed and provided).

Level 1–3 Defence Cyber Certification Process

While Level 0 requires very little sensitive information, level 1 and above requires significantly more and a different process.

The process for L1–3 will be different to L0. Please refer to the L1–3 Assessor Guide for full details.



Third-Party Assistance

The Defence Cyber Certification scheme is designed to promote cyber security resilience within the MOD supply chain, ensuring the highest standards of security for our nation's defences. To support organisations in achieving certification, third-party assistance is permitted under the following guidelines.

Role of Certification Bodies

Certification Bodies (CBs) play a critical role in maintaining the integrity of the scheme. They are expected to uphold the highest ethical standards, including:

- Acting impartially and providing unbiased guidance
- Promoting resilience and avoiding exploitation or creating dependency
- Maintaining transparency and fairness in their advisory and assessment roles

Permitted Actions

Certification Bodies may provide the following types of support to Applicants:

- Explain the DCC scheme and its levels
- Explain the controls and provide guidance on how to meet them
- Clarify questions and identify the key components needed to provide a complete and accurate response
- Describe the necessary evidence needed to demonstrate that a control has been met
- Verify the scope of the assessment
- Supply blank template documents
- Provide support to meet Cyber Essentials or Cyber Essentials Plus, as allowed under the current Cyber Essentials scheme

Prohibited Actions

To ensure fairness and maintain the integrity of the scheme, Certification Bodies may not:

- Implement policies, controls, or technical changes on behalf of the Applicant
- Answer questions on behalf of the Applicant or dictate the answers
- Complete documentation or prepare answers or evidence that they will later assess



If the Applicant requires more help than you can provide (e.g. consultation and implementation rather than advice), then you should recommend the Applicant engages a separate technology provider. This does not have to be a Certification Body, it can be any provider of the Applicant's choosing; however, it may be beneficial if the provider is familiar with DCC.

The Applicant is encouraged to discuss their scope (both DCC and CE) with you at an early stage. They are not obliged to do this, but they are strongly recommended to do this to prevent under scoping. Under scoping will lead to insufficient organisational coverage and ultimately failure to achieve certification.



Determining Scope

For some Applicants, this may be the most confusing part of the assessment. As an advising/assessing Certification Body, it is your responsibility to check the scoping and that it adequately covers the organisation. Some Applicants may under scope in an attempt to simplify their submission; your role is to ensure this does not happen. Alternatively, some Applicants may submit too large a scope and include elements and services that are not essential, e.g. vending machines. Whilst this is not a reason to fail, you should suggest modifying the scope to what is essential for the Applicant's organisation in order to reduce the effort required.

Applicants are asked to consider:

'What elements are essential for us continuing to operate as an organisation?'

1. First consider the core processes and systems that define you as a functioning organisation.
2. Now think about the following;
 - a. Tools/Technology
 - b. Operations/Logistics
 - c. Administration
 - d. Staff
 - e. Locations

As an Assessor, you must sufficiently understand the Applicant's organisation and its functions to determine if all of the essential parts are within the DCC scope. If you do not understand how the business works, then you cannot assess if the scope is correct and if the Applicant has sufficiently met a question or control. You are not expected to become an expert in the Applicant's industry, but you are expected to know the Applicant's organisation well.

It must be noted that any internet-connected devices/networks within the Defence Cyber Certification scope must fall within an appropriate Cyber Essentials certification scope (within the guidelines of Cyber Essentials). Please refer to Control 0001 (Cyber Essentials) and the separate Scoping Guidance for more information on the importance of Cyber Essentials scoping.



During the scoring phase, the Defence Cyber Certification and Cyber Essentials scopes will be reviewed by you, the Assessor. It is strongly

recommended that you and the Applicant discuss and agree the scope of the DCC assessment at an early stage (prior to submission) to prevent under scoping. If the scopes offer inadequate coverage, then the assessment will fail.

The scope must include all systems and business functions that are required to operate and deliver as a business in a secure and resilient manner.

There is a separate document containing scoping examples and overall scoping guidance. It is essential to discuss and agree the scoping with your Applicant as a first step as DCC is built upon the prerequisite of Cyber Essentials.

Answering the Questions

The available answer format is listed with each question, however, this alone does not provide enough detail for this assessment. The Applicant will also need to write a description of how they meet each control for each question and be ready to provide evidence to prove they meet a control in practice.

Their answers must:

- Concisely answer the questions asked
- Provide context of how their organisation currently meets the requirement
- Show they meet the overall control

The Applicant's response should correspond to the guidance we've provided in the Applicant guide (example answer outlines and supporting evidence), however, you may be asked to support with advice if they struggle to understand or answer the question. The Applicant will usually provide evidence to support their answer.

Your role as an Assessor is to understand the Applicant's answer, the context in which it is given, and whether this is adequate for the organisation based on your knowledge of it. If the Applicant's answers do not sufficiently address the questions, they should revise their responses. If they are unable to clarification in their submitted answers, you must discuss this with a suitable staff member during a call. If the response remains unclear and does not adequately meet the requirements of the question or the control, and sufficient clarification cannot be obtained, the question will be marked as failed.



Applicant's Evidence

The type and level of evidence to be provided varies from business to business. As such, each piece of evidence is assessed according to the question and the control it is linked to along with the scope and business context of that control. The evidence should support the answer/description/context, and this will aid in understanding how the control is met. This evidence must be readily available to show the Assessor when requested.

A key part of this scheme is the Applicant's collection of existing evidence. Note that evidence should not be created specifically to support the assessment.

This does not mean the Applicant is prohibited from providing screenshots or similar records of implementation. Ideally, however, we would like to see evidence of what the Applicant already had in place, as most controls should already be met. Part of the Applicant's process involves conducting a gap analysis when initially answering the questions. There may be instances where the Applicant identifies a control they do not meet and implements remediation to address it. While such evidence is not disregarded, you may want to review the surrounding evidence to verify its validity.

If the evidence provided by the Applicant directly answers the question and seems too good to be true, you must ensure that the evidence is genuine and accurately reflects what the Applicant is actually doing. While evidence can be tailored to address the specific question, it is generally expected that existing policies or measures will not align perfectly with the question. In cases where a policy is newly created, it may have been developed as a result of a gap analysis. However, most existing policies should have a verifiable history that can be reviewed for authenticity.

Documentation and Evidence Collection

The Applicant is expected to have a thorough understanding of their organisation and to identify any controls that are not being met, ideally addressing these issues before the assessment begins. The evidence provided must demonstrate that the controls are currently being met, rather than showing plans or work in progress to meet them in the future. However, it is possible for an ongoing project, even if not yet completed, to be sufficient to satisfy the requirements of the question or control.



If the Applicant does not provide all the needed information and this is noticed during the scoring, then this may result in failing the assessment.

Adequacy of evidence

If a control cannot reasonably be proven, then it will be failed.

Document retention

The Applicant is required to keep a copy of all documents used as part of the assessment for moderation and audit purposes. Once the assessment has been started, no documents in the final submitted pack must be edited. The only exception to this is where the assessor has requested additional clarification in the form of additional artefacts. These documents will provide a point-in-time snapshot showing the posture of their organisation at this moment. These documents must be kept for 3.5 years from the date of certification. This allows the Applicant to revisit the documents at a later stage which will aid:

- Creating an updated submission for certification renewal
- Creating an updated submission to upgrade the certification level
- Reapplying for certification if the scope has changed

Cross-referenced control considerations

As an Assessor, it is important to be mindful that evidence for one control may affect another. This can work for or against the Applicant as evidence or details shared can help strengthen their case and highlight positive aspects of their security practices.

Evidence, such as policies or screenshots, can often be used to support answers across multiple questions or controls. The scheme is designed to be flexible in the types of evidence accepted, helping to minimise the Applicant's workload. That said, the evidence provided must be sufficient and directly relevant to support their answers.

It's also important to note that while evidence may support one control, it could unintentionally conflict with or undermine another control. As an assessor you should carefully evaluate the evidence to ensure consistency and alignment across all responses.



Scoring Process

During this phase, the Assessor will review the submission. This will include a screenshare or video call to discuss the scope, answers and evidence to ensure the Assessor fully understands your organisation and your submission.

Level 0 has a single scoring phase.

There may be instances where the answers provided address the questions but do not clearly demonstrate whether the overall control is being met. In such cases, the Applicant should provide clarification. It is the Applicant's responsibility to confirm that they meet the controls, explain how they meet them, and provide evidence to demonstrate compliance. If they are unable to adequately prove that they meet the question requirements within the context of the control, the question will be marked as failed for that control.

DCC Applicant Data (IASME Portal)

These questions are not part of the Cyber Security Model question set, however, they are required for the certification scheme. Regardless of level, these questions must be answered by the Applicant on the IASME portal. Answers to the DCC Core questions may be answered elsewhere depending on the level.

These questions are:

- Organisation name (as registered at Companies House)
- What type of organisation are you? E.g. Ltd, CIC
- What is your organisation's registration number?
- What is your organisation's address?
- Size of organisation (roughly)



DCC Core Questions/Controls Labelling

Below is an example of a question ID and control number you and the Applicant will encounter in the Applicant Guide. The levels indicated in brackets after the MOD question ID represent the DCC scheme levels to which the specific question or control applies.

IASME has retained these values from Def Stan and the MOD supply chain as follows;

EXAMPLE

0001.1 – (MOD 000011) – (L0-L3)

0001.1	MOD 000011	L0-L3
The question ID	The MOD supply chain portal Question ID	The level covered

The question ID is made up of two elements, the control (eg 0001) and where this question sits within the control (eg .1 indicating it is the first question, .2 the second and so on).

You may notice that the MOD numbering is not linear, this does not affect our scheme but may confuse Applicants who expect it to be linear. The Applicant may notice that the question order in our Applicant Guide does not always match that of the MOD SQA platform, this is because we have changed the order of some questions to improve the flow. The MOD question IDs have not changed.

Where possible, IASME have used the same criteria (questions, answers and levels) as the MOD SAQ, but this has not always been possible. For instance, 2314.2 – (MOD 000446) is L0-3 in DCC but L2-3 on the MOD SAQ platform. Some questions may have minor adjustments to their wording to improve clarity or enhance understanding; however, the intent of the questions remains unchanged.



Control Guidance

Control ID: 0001	Control Short Name: Cyber Essentials	DCC Levels: L0-3
Requirement: The Applicant shall have Cyber Essentials certification that covers the scope required for all aspects of the contract and commit to maintaining this for the duration of the contract.		
Guidance: 1) Applicant Expectations: a. The Applicant must hold a current Cyber Essentials certificate; this certificate should cover the scope of services delivered to the MOD and be issued to the same organisation supplying the services or products. b. Please be aware that some organisations might hold more than one Cyber Essentials certificate to make sure every part of their network is covered. 2) Policy: a. A policy is not required but attaining/maintaining Cyber Essentials may be covered within policies 3) Implementation Evidence: a. Cyber Essentials certificate (in scope for the services provided) as document or screenshot. b. Verify accuracy of details (organisation name, date, scope) by checking cert number on IASME site c. Cyber Essentials VSA (questionnaire) 4) Operational Effectiveness Testing: a. Covered by implementation evidence. 5) Guiding Questions: a. Does your organisation have a valid Cyber Essentials certificate which covers the scope of the		



Control ID: 0001	Control Short Name: Cyber Essentials	DCC Levels: L0-3
Requirement: The Applicant shall have Cyber Essentials certification that covers the scope required for all aspects of the contract and commit to maintaining this for the duration of the contract.		
services/products provided? b. Does the Cyber Essentials scope adequately cover the DCC assessment scope? Refer to Scoping Guidance document for more information. c. If the Cyber Essentials scope differs significantly and does not adequately cover the DCC scope, then ask for clarification. If none is provided then do not proceed past this point. There may be slight differences as networks change with time and the Applicant may have taken some time between Cyber Essentials and DCC. 6) Considerations: a. Organisations may undertake Cyber Essentials and submit a small/restricted scope to pass Cyber Essentials b. Does the Cyber Essentials scope description make sense for this organisation size and function? c. It is possible an Applicant may rename/label parts of their network to match the Cyber Essentials Scope, check the Cyber Essentials report to determine if there has been a large change in the scope (e.g. number of hosts, size/location of networks) d. If the network names/scope have changed, then did it follow the change management policy? e. The DCC Assessor role is not to moderate the Cyber Essentials submission, only to ensure it is adequate for DCC. However, if an issue is found, please let IASME know. If Cyber Essentials not held then do not proceed, overall automatic fail. If Cyber Essentials scope not sufficient or adequately aligned to DCC, then overall automatic fail.		



Control ID: 2314	Control Short Name: Ensure UK GDPR Compliance	DCC Levels: L0-3
Requirement: The Applicant shall ensure that the processing of personal data is conducted in compliance with the General Data Protection Regulation.		
Guidance: 1. Applicant Expectations: a. The Applicant should comply with GDPR requirements when processing Personally Identifiable Information (PII). b. Data subjects' consent must be obtained and recorded and they must be informed that they can withdraw their consent at any point. Data deletion requests from individuals should be reviewed and responded to confirm the identity of the requestor and whether the data can be deleted. c. Compliance assessments and DPIAs should be conducted to identify and mitigate risks associated with data processing activities. 2. Policy: a. Documentation or policies outlining the requirement to comply with GDPR when processing PII. b. Documentation or policies outlining the requirement to conduct DPIA and compliance assessments. 3. Implementation Evidence: a. The Applicant's Data Protection Officer details. b. Evidence of data processing template clauses to include within contract where personal data is processed. c. Evidence of data processing assessment which determines what personal information is required and who has access. d. Documentation evidencing that data subjects are informed of all their rights. e. Evidence of clear data processing and legal justification in the Applicant's privacy policy.		



4. Operational Effectiveness Testing:

- a. Walkthrough: Test the process for obtaining and recording data subjects' consent to ensure it complies with GDPR requirements.
- b. Logs/records showing review and response to data deletion requests, including identity verification.
- c. Reports from GDPR compliance assessments conducted within the last 12 months.
- d. Reports from DPIAs conducted within the last 12 months.

5. Guiding Questions:

- a. Explain the process for ensuring GDPR compliance when processing PII.
- b. How are data subjects' consent obtained and recorded?
- c. How are data deletion requests reviewed and responded to?

6. Considerations:

- a. Have there been any breaches? If so, what happened and is this a thread to follow?
- b. It is important to note that assessing this control does not guarantee GDPR compliance, only that the Applicant has suitable policies and processes in place to meet GDPR and you have not found any evidence that GDPR is not met.



Control ID: 2500	Control Short Name: Resilient Networks and Systems	DCC Levels: L0-3
Requirement: The Applicant shall build resilience against cyber attack and system failure into their design, implementation, operation and management of systems that support the operation of Functions and protection of Data.		
Guidance: 1. Applicant Expectations: a. The Applicant should ensure cyber resilience is built into network and system design to protect against cyber attack and system failures. Resilience requirements should be considered across all stages of the network and system life cycle, covering design, implementation, operation and management of systems. 2. Policy: a. Documentation or policies outlining the requirement to integrate resilience into the design, implementation, operation and management for systems. 3. Implementation Evidence: a. Documentation showing the integration of resilience into the design and implementation of systems, services and/or business processes. 4. Operational Effectiveness Testing: a. Walkthrough to observe the resilience measures integrated into the design, implementation, operation, and management of systems. 5. Guiding Questions: a. Explain the process for integrating resilience into the design, implementation, operation, and management of systems. b. How are resilience requirements identified, analysed and incorporated across all stages of the system life cycle?		



6. Considerations:

- a. Does the evidence fit the size/type of company and the type of threats it will likely face?

